SECURITY & OBSERVABILITY

SECURITY

AuthN/Z
OAuth2/OIDC login, short-lived JWT (15 min) verified at gateway; RBAC for admin/ops; service-to-service mTLS.

Transport
TLS 1.2+ everywhere, HSTS; internal mTLS.

Rate limiting / abuse
Per-IP, per-user, per-device token buckets at edge and gateway; bot challenge (CAPTCHA/proof-of-work) before Buy; 1 unit per customer; account-age checks.

Input validation
Schema validation (OpenAPI) at gateway; qty = 1; parameterised SQL only.

Payment data
Hosted fields / gateway tokens; no PAN/CVV stored (PCI SAQ-A scope); webhook HMAC signature + timestamp check; replay protection via txn ref.

Idempotency safety
Keys scoped to user + endpoint, TTL 24 h; payload hash must match for the same key.

Audit
Append-only audit of inventory, payment and order state changes (who/what/when/trace_id); logs exclude secrets and PII.

Secrets
Vault/KMS; rotation; no secrets in code or images.

Data
Encryption at rest; least-privilege DB roles per service.

OBSERVABILITY

KEY METRICS (RED + business)

1. Metric : Request rate, p50/p95/p99 latency, error rate per endpoint
   Alert : p99 > 500 ms for 2 min; 5xx > 1%

2. Metric : reservation_success, reservation_sold_out, reservation_duplicate
   Alert : Sudden drop in success while stock > 0

3. Metric : inventory_mismatch (Redis vs DB, and available+reserved+sold != total)
   Alert : ANY NON-ZERO -> PAGE

4. Metric : payment_success_rate, payment_unknown_count, gateway latency, breaker state
   Alert : Success < 90%; breaker open > 1 min; UNKNOWN older than 5 min

5. Metric : payments_without_order (reconciler)
   Alert : > 0 for 2 min

6. Metric : Kafka consumer lag, DLQ depth
   Alert : Lag > 30 s; any DLQ message

7. Metric : Order conversion (reserved -> paid -> confirmed)
   Alert : Conversion < 85%

8. Metric : Expiry worker lag
   Alert : Expired reservations unreleased > 1 min

STRUCTURED LOGS (JSON)
  Fields: ts, level, service, trace_id, span_id, event, reservation_id,
  payment_id, order_id, user_id_hash, sku, from_state, to_state, result,
  latency_ms

  Critical events: ReservationCreated/Released,
  PaymentInitiated/Succeeded/Failed/Unknown, OrderCreated, RefundIssued,
  DLQ moves.

TRACING
  OpenTelemetry; trace_id created at gateway, propagated in HTTP headers and
  Kafka message headers across reserve -> checkout -> payment -> order ->
  shipment -> notification.

  Dashboards: sale funnel, inventory conservation, payment health, queue lag.
  Tools: Prometheus + Grafana, Loki, Jaeger.